

ECDAT — Engineering Completion Report

PS 26164 · NTRO · Enterprise Cryptographic Discovery & Analysis Tool. MVP complete: 37/37 acceptance tests pass; CycloneDX 1.6 CBOM validates against the official schema.

1. What was built (vertical slice)

- Source scanner: Python + Java crypto API detection (RSA, ECDSA/DSA, ECDH/X25519, AES, SHA-256/384/512, MD5, SHA-1, DES/3DES).
- Dependency scanner: requirements.txt + pom.xml → library/version crypto assets.
- Certificate scanner: PEM/DER X.509 metadata (subject, issuer, key size, validity).
- Config scanner: nginx/TLS configs → TLS versions, cipher suites, DH params.
- Normalisation → unified CryptoAsset model with evidence (file, line, rule, confidence).
- Quantum classification (SHOR_BROKEN / GROVER_WEAKENED / QUANTUM_SAFE / CLASSICALLY_BROKEN) + HNDL/TNFL.
- Mosca $X + Y > Z$ engine with scenario-year selector (2030/2035/2040).
- Transparent 0–100 risk score + deterministic NIST FIPS 203/204/205 recommendations.
- CycloneDX 1.6 CBOM generation + schema validation.
- 6-page Streamlit dashboard (Dashboard / New Scan / Inventory / Asset Detail / Mosca / Reports).

2. Measured results (controlled corpus)

Metric	Value
Total assets detected	41
Quantum-vulnerable (Shor)	30
Classically broken	5
Mosca violations ($X+Y>Z$)	30
Critical-risk assets	29
High / Medium risk	6 / 5
Planted classes recalled	10 / 10 (recall = 1.00)
Scan time	0.133 s
CBOM schema validation	PASS (official CycloneDX 1.6)

3. Real open-source target (CPython 3.11 stdlib)

Metric	Value
Total assets detected	695
Quantum-vulnerable (Shor)	681

Metric	Value
Classically broken	9
Scan time	25.1 s
CBOM schema validation	PASS

Note: the high RSA count on the real target reflects the broad LOW-confidence 'RSA' heuristic matching common stdlib/doc text; confidence is reported honestly per asset. Compiled binary wheels (e.g. pyca/cryptography .pyd) return 0 findings as expected — source scanning targets plain-text source.

4. Acceptance gates

[x] Python + Java discovery [x] Evidence [x] Dependency versions [x] Certificate metadata [x] Quantum classification [x] HNDL/TNFL [x] Type/lifetime/criticality [x] Mosca X+Y>Z [x] Risk score [x] PQC recommendation [x] CycloneDX 1.6 CBOM [x] CBOM validation PASS [x] Dashboard runs cleanly [x] 37/37 tests [x] Real metrics [x] 6-slide deck

5. How to run

Launch app: `python run.py` (or: `streamlit run app/ui/dashboard.py`)

Run tests: `python -m pytest tests/ -q`

Controlled corpus: `test_corpus/` · Real demo target: `test-data/sample-project/`

CBOM: `output/cbom/ECDAT_controlled_corpus_cbom.json` · Deck: `output/ECDAT_SIH_6Slide.pptx` · Metrics: `output/metrics.json`

6. Limitations & roadmap

- Source scanning is regex/rule-based; heuristic LOW-confidence matches possible.
- Compiled binaries / OCI layers not analysed (ROADMAP).
- Live TLS endpoint probe / SSH probe = OPTIONAL (implemented on request).
- Cloud inventory (AWS/Azure/GCP), HSM enumeration, C/C++/Go/Rust = ROADMAP.
- No private key material is ever stored or displayed (verified by test).